

Open items & decisions

The honest punch-list. Nothing here blocks a demo; several items block taking a real client's data. Grouped by when they must be done.

See `README.md` .

Before the first real client sprint (must-do)

#	Item	Why	Owner
1	Per-user facilitator logins (replace the shared password)	Accountability + audit + revocation; the #1 security gap	Build
2	Get the three DPAs on file — Anthropic (accept), Vercel (accept), Turso (request via trust portal)	Art. 28 requires them before processing	Founders
3	Verify Anthropic DPF status at <code>dataprivacyframework.gov/list</code>	Transfer assessment; sources conflict — don't state unconfirmed	Founders
4	Confirm SCC versions in all three DPAs; confirm Turso's transfer mechanism	The transfer story depends on it	Lawyer
5	Wire the privacy notices in (08_...) — crew notice on intake, panel consent on the test view	Art. 13 information duty + consent must actually be shown	Build
6	Legal review of the DPA + DPIA (03_... , 06_...)	They're binding/regulated instruments	Lawyer / DPO
7	Confirm panel consent + incentive process and recording	Lawful basis for the consumer panel	Panel host

Before scaling past the pilot (should-do)

#	Item	Why
8	MFA on facilitator accounts	Credential-compromise resistance
9	Access audit logging on facilitator routes	Show who accessed what
10	Schedule <code>npm run backup</code> (cron / Vercel Cron)	No missed backup before an incident
11	One-page incident-response runbook	Faster, consistent breach handling + the 24/48h clock
12	Client-link expiry / rotation	Bearer-token links shouldn't live forever

#	Item	Why
13	Light penetration test	Unknown unknowns

Strategic decision (only if a client requires it)

#	Decision	Trade-off
14	Move AI processing to the EU (Claude on AWS Bedrock EU / Vertex <code>region:"eu"</code>)	Removes the US transfer entirely; costs an architecture change (SDK/auth/model-id) + model-availability check. Decide only if a client makes EU AI residency a condition.
15	Pin Anthropic <code>inference_geo:"us"</code> as an interim	Makes the US transfer definite and documentable (vs. "global/anywhere") at ~1.1× cost; still US. Cheap middle option.

Already done (this pass)

- App compute pinned to **EU — Frankfurt** (`vercel.json`).
- Working **erasure** (`npm run delete-sprint`) and **backup** (`npm run backup`).
- Honest data-flow, subprocessor list, DPA template, retention policy, TOMs, DPIA input, security questionnaire, Dutch notices drafted.
- Confirmed no secrets in git; secrets via env only.